CUSTOM COMPILED EVIDENCE DOSSIER · NOT A NATIVE SONARCLOUD PDF

Detailed Security Evidence Team Notes

Issue records, source excerpts and source-linked rule guidance for independent learner analysis.

> **Artifact identity.** This companion was assembled from supplied SonarCloud exports. The original `security-report.pdf` is preserved separately. It does not represent a new scan, exploit, test run or verified remediation.

Project	Team Notes (SonarQube Training)
Project key	mikelopster_sonarqube-training-team-notes
Reported branch label	master
Core analysis date	2026-10-10T07:40:51+0000
Core analysis ID	651e6e22-465a-40ac-8548-6e8c7bad1e10
Analyzed commit SHA	Unknown / not supplied
Original PDF generated	2026-10-18T03:44:00Z
Original PDF SHA-256	9299a50dd43f368acee48f04657ce79deec83e5a6243bb07cec03c8421486e48
Detailed exports captured	2026-10-18T09:48:35.952Z
Issue query / scope	GET /api/issues/search?componentKeys=mikelopster_sonarqube-training-team-notes&branch=master&impactSoftwareQualities=SECURITY&ps=500&p=1&additionalFields=_all
Native report coverage	Overall Code; New Code security count is unavailable (-), not zero.
Distinct issue records here	13

- Not supplied by the downloaded PDF or project_analyses response. Do not assume the current main checkout matches.
- Rule definitions/standards were retrieved at current capture time; do not assume they are frozen to the analysis date.
- Security-impact and legacy VULNERABILITY filters returned the same13 issue keys. All results fit in page1.

Read the evidence in context

- Different report sections use category mappings. Do not equate their totals with distinct issue IDs.
- No tests, exploit attempts, rescan or remediation were performed to produce this teaching package.

- Server source snapshots are evidence from the analysis UI, not proof of deployed code or runtime reachability.
- Source and issue exports are static evidence. Issue status and rule metadata reflect capture time, not a newly executed analysis.
- The ten source files are redacted publication copies. Raw-response SHA-256 and published-file SHA-256 are different for masked files.
- Rule explanations are source-linked summaries. They are not a confirmed exploit or a validated patch for this application.

Severity labels below are copied from their named API fields. Legacy severity and software-quality impact severity are different scales; neither is a runtime exploit result. Category totals in the original PDF can count the same issue more than once.

Native PDF overview · original recorded counts

Overview open security issues	13
Sonar category total	20
OWASP category total	17
Dependency risks	1
Hotspots to review	0

These are the native PDF section counts, not a deduplicated sum. The detailed issue list below is a separate API export.

Issue index

1. githubactions:S6505 · PDF p. 4
mikelopster_sonarqube-training-team-notes:.github/workflows/sonarqube.yml · line 32
AaEkwytqn3atgy46CG_m

2. csharpsquid:S2068 · PDF p. 6
mikelopster_sonarqube-training-team-notes:api/AppConfig.cs · line 11
AaEkwyskn3atgy46CG_Y

3. secrets:S6698 · PDF p. 8
mikelopster_sonarqube-training-team-notes:api/AppConfig.cs · line 12
AaEkwyskn3atgy46CG_W

4. csharpsquid:S4790 · PDF p. 10
mikelopster_sonarqube-training-team-notes:api/Auth.cs · line 21
AaEkwyq6n3atgy46CG_F

5. csharpsquid:S3330 · PDF p. 12
mikelopster_sonarqube-training-team-notes:api/Endpoints/AuthEndpoints.cs · line 35
AaEkwyrvn3atgy46CG_O

6. csharpsquid:S2092 · PDF p. 14
mikelopster_sonarqube-training-team-notes:api/Endpoints/AuthEndpoints.cs · line 35
AaEkwyrvn3atgy46CG_P

7. csharpsquid:S2077 · PDF p. 16
mikelopster_sonarqube-training-team-notes:api/Endpoints/Mutations.cs · line 42
AaEkwysMn3atgy46CG_S

8. roslyn.sonaranalyzer.security.cs:S5144 · PDF p. 18
mikelopster_sonarqube-training-team-notes:api/Endpoints/PreviewEndpoints.cs · line 33
AaEkwyrXn3atgy46CG_H

9. secrets:S6698 · PDF p. 20
mikelopster_sonarqube-training-team-notes:api/appsettings.json · line 11
AaEkwysdn3atgy46CG_U

10. csharpsquid:S2068 · PDF p. 22
mikelopster_sonarqube-training-team-notes:api/appsettings.json · line 11
AaEkwysdn3atgy46CG_V

11. docker:S6505 · PDF p. 24
mikelopster_sonarqube-training-team-notes:web/Dockerfile · line 7
AaEkwys4n3atgy46CG_e

12. typescript:S5332 · PDF p. 26
mikelopster_sonarqube-training-team-notes:web/lib/api.ts · line 3
AaEkwytWn3atgy46CG_i

13. typescript:S5332 · PDF p. 28
mikelopster_sonarqube-training-team-notes:web/next.config.ts · line 5
AaEkwytjn3atgy46CG_k

ISSUE 1 OF 13

JavaScript package manager scripts should not be executed during installation

AaEkwytqn3atgy46CG_m

Legacy severity: MAJOR | Status: OPEN | Issue status: OPEN

Rule ID	githubactions:S6505
Type	VULNERABILITY
File/component	mikelopster_sonarqube-training-team-notes:.github/workflows/sonarqube.yml
Reported range	32–32
Created / updated	2026-10-10T07:40:51+0000 / 2026-10-10T07:40:51+0000

What Sonar reported

Omitting "--ignore-scripts" allows lifecycle scripts to run during package installation.

Software-quality impacts: SECURITY: MEDIUM

Source excerpt at the reported location

```
27        - uses: actions/setup-node@v5
28          with:
29            node-version: 24
30
31        # ---- web: unit tests + lcov coverage ----------------------------------
32        - run: npm ci
33          working-directory: web
34        # XSS tests fail on `main` by design; keep going so lcov is still produced and imported.
35        - run: npm run test:coverage
36          working-directory: web
37          continue-on-error: true
```

Source provenance	SonarCloud api/sources/raw and api/sources/lines, branch=master
Published source file	detailed/sources/.github/workflows/sonarqube.yml
Raw API bytes SHA-256	872c78f32207267b52730cebd921972def6c51aabda5a1b493a041a61afc40ef
Published file SHA-256	872c78f32207267b52730cebd921972def6c51aabda5a1b493a041a61afc40ef
Hash definition	sha256 of the full UTF-8 response bytes from SonarCloud api/sources/raw, before publication redaction; not a Git commit or deployment identity
Analyzed SCM revision	Unknown / not supplied

Flow locations included in the export

No flow locations supplied. This does not prove that data flow is absent.

Rule guidance

Source-linked explanatory summary, not a verified fix for this application.

Why this rule raises the issue

Package installation can execute lifecycle scripts supplied by dependencies.

Potential risks described by the rule

A compromised dependency can run code with the build process permissions and expose credentials or alter artifacts.

Remediation guidance from the rule

Review whether installation scripts are needed and use the package manager controls that disable unaudited scripts; test required build functionality afterwards.

Rule reference: https://rules.sonarsource.com/githubactions/RSPEC-6505/

Rule retrieved at	2026-10-18T09:48:32.891Z
Rule security mappings	cwe:506, cwe:829

Context still needed

- Whether this snapshot matches the build and deployed system being assessed.
- Relevant trust boundaries, reachable inputs and compensating controls; no runtime proof is included.
- Whether a proposed change preserves intended behavior and passes appropriate tests.

Questions above are review prompts, not claims that a vulnerability was exploited or a fix validated.

ISSUE 2 OF 13

Credentials should not be hard-coded

AaEkwyskn3atgy46CG_Y

Legacy severity: MAJOR | Status: OPEN | Issue status: OPEN

Rule ID	csharpsquid:S2068
Type	VULNERABILITY
File/component	mikelopster_sonarqube-training-team-notes:api/AppConfig.cs
Reported range	11–12
Created / updated	2026-10-10T07:40:51+0000 / 2026-10-10T07:40:51+0000

What Sonar reported

Review this hard-coded URI, which may contain a credential.

Software-quality impacts: SECURITY: MEDIUM

Source excerpt at the reported location

```
6  /// </summary>
7  public static class AppConfig
8  {
9      // Falls back to the shared staging database when DATABASE_URL is not set.
10     // (Lab 2 secrets: a PostgreSQL password hard-coded in the source.)
11     public const string FallbackDatabaseUrl =
12         "postgres://notes:[REDACTED]@db.staging.internal:5432/notes";
13
14     // Used to sign the session JWT (HS256). Hard-coded signing key.
15     public const string JwtSecret = "[REDACTED]";
16
17     // Attachment storage (S3) - TODO: move to env vars before go-live
```

Source provenance	SonarCloud api/sources/raw and api/sources/lines, branch=master
Published source file	detailed/sources/api/AppConfig.cs
Raw API bytes SHA-256	645dd26e14c260c48a1f0f64d5d289e985ec2c203df39a15da4c8ab1ad0f0387
Published file SHA-256	a1ce736977d9268d91d200153af48ed30330fb7841b2f89f744aa6a6f73ef04c
Hash definition	sha256 of the full UTF-8 response bytes from SonarCloud api/sources/raw, before publication redaction; not a Git commit or deployment identity
Analyzed SCM revision	Unknown / not supplied

Credential literals were masked in the published copy at lines 12, 15, 20, 21. The raw-response hash and published-file hash are separate identities. Source structure/line numbers are preserved; a mask is not the original credential.

Flow locations included in the export

No flow locations supplied. This does not prove that data flow is absent.

Rule guidance

Source-linked explanatory summary, not a verified fix for this application.

Why this rule raises the issue

Credentials embedded in code or connection strings are distributed with the source or application.

Potential risks described by the rule

Readers of a repository, build artifact or backup may obtain access to the associated service.

Remediation guidance from the rule

Move credentials to an appropriate protected configuration or secrets service. Rotate any genuinely exposed credential; moving it alone does not revoke it.

Rule reference: https://rules.sonarsource.com/csharp/RSPEC-2068/

Rule retrieved at	2026-10-18T09:48:33.307Z
Rule security mappings	cwe:259, cwe:798, owaspAsvs-4.0:2.10.4, owaspAsvs-4.0:3.5.2, owaspAsvs-4.0:6.4.1, owaspTop10-2021:a7, owaspTop10:a2, pciDss-3.2:6.5.10, pciDss-4.0:6.2.4

Context still needed

- Whether this snapshot matches the build and deployed system being assessed.
- Relevant trust boundaries, reachable inputs and compensating controls; no runtime proof is included.
- Whether a proposed change preserves intended behavior and passes appropriate tests.

Questions above are review prompts, not claims that a vulnerability was exploited or a fix validated.

ISSUE 3 OF 13

PostgreSQL database passwords should not be disclosed

AaEkwyskn3atgy46CG_W

Legacy severity: BLOCKER | Status: OPEN | Issue status: OPEN

Rule ID	secrets:S6698
Type	VULNERABILITY
File/component	mikelopster_sonarqube-training-team-notes:api/AppConfig.cs
Reported range	12–12
Created / updated	2026-10-10T07:40:51+0000 / 2026-10-10T07:40:51+0000

What Sonar reported

Make sure this PostgreSQL password gets changed and removed from the code.

Software-quality impacts: SECURITY: BLOCKER

Source excerpt at the reported location

```
 7  public static class AppConfig
 8  {
 9      // Falls back to the shared staging database when DATABASE_URL is not set.
10      // (Lab 2 secrets: a PostgreSQL password hard-coded in the source.)
11      public const string FallbackDatabaseUrl =
12          "postgres://notes:[REDACTED]@db.staging.internal:5432/notes";
13
14      // Used to sign the session JWT (HS256). Hard-coded signing key.
15      public const string JwtSecret = "[REDACTED]";
16
17      // Attachment storage (S3) - TODO: move to env vars before go-live
```

Source provenance	SonarCloud api/sources/raw and api/sources/lines, branch=master
Published source file	detailed/sources/api/AppConfig.cs
Raw API bytes SHA-256	645dd26e14c260c48a1f0f64d5d289e985ec2c203df39a15da4c8ab1ad0f0387
Published file SHA-256	a1ce736977d9268d91d200153af48ed30330fb7841b2f89f744aa6a6f73ef04c
Hash definition	sha256 of the full UTF-8 response bytes from SonarCloud api/sources/raw, before publication redaction; not a Git commit or deployment identity
Analyzed SCM revision	Unknown / not supplied

Credential literals were masked in the published copy at lines 12, 15, 20, 21. The raw-response hash and published-file hash are separate identities. Source structure/line numbers are preserved; a mask is not the original credential.

Flow locations included in the export

No flow locations supplied. This does not prove that data flow is absent.

Rule guidance

Source-linked explanatory summary, not a verified fix for this application.

Why this rule raises the issue

The rule identifies a PostgreSQL password in source.

Potential risks described by the rule

A disclosed database password may permit unauthorized access according to the account permissions and network exposure.

Remediation guidance from the rule

Revoke or change exposed credentials, remove the value from uncontrolled distribution and use a protected secret source. Verify the real affected account and context.

Rule reference: https://rules.sonarsource.com/secrets/RSPEC-6698/

Rule retrieved at	2026-10-18T09:48:33.712Z
Rule security mappings	cwe:259, cwe:798, owaspAsvs-4.0:2.10.4, owaspAsvs-4.0:3.5.2, owaspAsvs-4.0:6.4.1, owaspTop10-2021:a7, owaspTop10:a3, pciDss-3.2:6.5.10, pciDss-4.0:6.2.4, stig-ASD_V5R3:V-222642

Context still needed

- Whether this snapshot matches the build and deployed system being assessed.
- Relevant trust boundaries, reachable inputs and compensating controls; no runtime proof is included.
- Whether a proposed change preserves intended behavior and passes appropriate tests.

Questions above are review prompts, not claims that a vulnerability was exploited or a fix validated.

ISSUE 4 OF 13

Weak hashing algorithms should not be used

AaEkwyq6n3atgy46CG_F

Legacy severity: CRITICAL | Status: OPEN | Issue status: OPEN

Rule ID	csharpsquid:S4790
Type	VULNERABILITY
File/component	mikelopster_sonarqube-training-team-notes:api/Auth.cs
Reported range	21–21
Created / updated	2026-10-10T07:40:51+0000 / 2026-10-10T07:40:51+0000

What Sonar reported

Use a stronger hashing algorithm.

Software-quality impacts: SECURITY: HIGH

Source excerpt at the reported location

```
16      // ---- passwords ------------------------------------------------------------
17      // Day 1 vuln: unsalted MD5. Fast, unsalted, broken: identical passwords share a digest
18      // and GPU rainbow tables reverse it instantly.
19      public string HashPassword(string password)
20      {
21          byte[] digest = MD5.HashData(Encoding.UTF8.GetBytes(password));
22          return Convert.ToHexString(digest).ToLowerInvariant();
23      }
24
25      public bool VerifyPassword(string password, string storedHash)
26          => string.Equals(HashPassword(password), storedHash, StringComparison.OrdinalIgnoreCase);
```

Source provenance	SonarCloud api/sources/raw and api/sources/lines, branch=master
Published source file	detailed/sources/api/Auth.cs
Raw API bytes SHA-256	613c2eb914ba9ad92d82d215c9ea5e20cc9ac4ff8de42afeac42f19d8faff948
Published file SHA-256	613c2eb914ba9ad92d82d215c9ea5e20cc9ac4ff8de42afeac42f19d8faff948
Hash definition	sha256 of the full UTF-8 response bytes from SonarCloud api/sources/raw, before publication redaction; not a Git commit or deployment identity
Analyzed SCM revision	Unknown / not supplied

Flow locations included in the export

No flow locations supplied. This does not prove that data flow is absent.

Rule guidance

Source-linked explanatory summary, not a verified fix for this application.

Why this rule raises the issue

Weak or unsuitable hashes can undermine the purpose of protecting sensitive data.

Potential risks described by the rule

Password hashes may permit inexpensive guessing, while weak hashes used for integrity may permit substitution attacks. The exact impact depends on use.

Remediation guidance from the rule

Use a suitable password KDF for password storage, and modern cryptographic hashes for appropriate non-password integrity uses; choose and verify settings for the use case.

Rule reference: https://rules.sonarsource.com/csharp/RSPEC-4790/

Rule retrieved at	2026-10-18T09:48:34.013Z
Rule security mappings	cwe:1240, owaspTop10-2021:a2, owaspTop10:a3, owaspTop10:a6, pciDss-3.2:3.4, pciDss-3.2:6.5.3, pciDss-3.2:6.5.4, pciDss-4.0:6.2.4

Context still needed

- Whether this snapshot matches the build and deployed system being assessed.
- Relevant trust boundaries, reachable inputs and compensating controls; no runtime proof is included.
- Whether a proposed change preserves intended behavior and passes appropriate tests.

Questions above are review prompts, not claims that a vulnerability was exploited or a fix validated.

ISSUE 5 OF 13

Cookies should have the "HttpOnly" flag

AaEkwyrvn3atgy46CG_O

Legacy severity: MINOR | Status: OPEN | Issue status: OPEN

Rule ID	csharpsquid:S3330
Type	VULNERABILITY
File/component	mikelopster_sonarqube-training-team-notes:api/Endpoints/AuthEndpoints.cs
Reported range	35–39
Created / updated	2026-10-10T07:40:51+0000 / 2026-10-10T07:40:51+0000

What Sonar reported

Set the 'HttpOnly' flag on this cookie.

Software-quality impacts: SECURITY: LOW

Source excerpt at the reported location

```
30
31          string token = auth.CreateSessionToken(new Session(user.id, user.team_id, user.role,
    user.email));
32
33          // Day 1 vuln: the session cookie is not HttpOnly, not Secure and has no SameSite, so
34          // client-side JS (an XSS payload) can read it and it rides along on cross-site requests.
35          ctx.Response.Cookies.Append(AuthService.SessionCookie, token, new CookieOptions
36          {
37              Path = "/",
38              HttpOnly = false,
39          });
40          return ApiHelpers.SeeOther(next);
41      }
42
43      private static IResult Logout(HttpContext ctx)
44      {
```

Source provenance	SonarCloud api/sources/raw and api/sources/lines, branch=master
Published source file	detailed/sources/api/Endpoints/AuthEndpoints.cs
Raw API bytes SHA-256	18310475693c4cb410773fc048320bc0793ad060aa8b8ff74d0c269b00479a5e
Published file SHA-256	18310475693c4cb410773fc048320bc0793ad060aa8b8ff74d0c269b00479a5e
Hash definition	sha256 of the full UTF-8 response bytes from SonarCloud api/sources/raw, before publication redaction; not a Git commit or deployment identity
Analyzed SCM revision	Unknown / not supplied

Flow locations included in the export

No flow locations supplied. This does not prove that data flow is absent.

Rule guidance

Source-linked explanatory summary, not a verified fix for this application.

Why this rule raises the issue

A cookie without HttpOnly can be read by scripts in the page context.

Potential risks described by the rule

If an XSS path exists, a script-readable session cookie can be stolen and used for impersonation.

Remediation guidance from the rule

Enable HttpOnly for sensitive cookies and verify actual Set-Cookie behavior. This control does not itself remove XSS or stop every authenticated action from an injected script.

Rule reference: https://rules.sonarsource.com/csharp/RSPEC-3330/

Rule retrieved at	2026-10-18T09:48:34.316Z
Rule security mappings	cwe:1004, owaspAsvs-4.0:3.4.2, owaspTop10-2021:a5, owaspTop10:a7, pciDss-3.2:6.5.10, pciDss-4.0:6.2.4, stig-ASD_V5R3:V-222575

Context still needed

- Whether this snapshot matches the build and deployed system being assessed.
- Relevant trust boundaries, reachable inputs and compensating controls; no runtime proof is included.
- Whether a proposed change preserves intended behavior and passes appropriate tests.

Questions above are review prompts, not claims that a vulnerability was exploited or a fix validated.

ISSUE 6 OF 13

Cookies should have the "secure" flag

AaEkwyrvn3atgy46CG_P

Legacy severity: MINOR | Status: OPEN | Issue status: OPEN

Rule ID	csharpsquid:S2092
Type	VULNERABILITY
File/component	mikelopster_sonarqube-training-team-notes:api/Endpoints/AuthEndpoints.cs
Reported range	35–39
Created / updated	2026-10-10T07:40:51+0000 / 2026-10-10T07:40:51+0000

What Sonar reported

Set the 'Secure' flag on this cookie.

Software-quality impacts: SECURITY: LOW

Source excerpt at the reported location

```
30
31          string token = auth.CreateSessionToken(new Session(user.id, user.team_id, user.role,
    user.email));
32
33          // Day 1 vuln: the session cookie is not HttpOnly, not Secure and has no SameSite, so
34          // client-side JS (an XSS payload) can read it and it rides along on cross-site requests.
35          ctx.Response.Cookies.Append(AuthService.SessionCookie, token, new CookieOptions
36          {
37              Path = "/",
38              HttpOnly = false,
39          });
40          return ApiHelpers.SeeOther(next);
41      }
42
43      private static IResult Logout(HttpContext ctx)
44      {
```

Source provenance	SonarCloud api/sources/raw and api/sources/lines, branch=master
Published source file	detailed/sources/api/Endpoints/AuthEndpoints.cs
Raw API bytes SHA-256	18310475693c4cb410773fc048320bc0793ad060aa8b8ff74d0c269b00479a5e
Published file SHA-256	18310475693c4cb410773fc048320bc0793ad060aa8b8ff74d0c269b00479a5e
Hash definition	sha256 of the full UTF-8 response bytes from SonarCloud api/sources/raw, before publication redaction; not a Git commit or deployment identity
Analyzed SCM revision	Unknown / not supplied

Flow locations included in the export

No flow locations supplied. This does not prove that data flow is absent.

Rule guidance

Source-linked explanatory summary, not a verified fix for this application.

Why this rule raises the issue

A cookie without Secure can be transmitted over an unencrypted HTTP connection.

Potential risks described by the rule

An attacker able to observe that connection may obtain a sensitive cookie.

Remediation guidance from the rule

Use Secure for sensitive cookies over HTTPS and validate transport behavior. Account for the actual deployment and the intentionally plain-HTTP training environment when planning a change.

Rule reference: https://rules.sonarsource.com/csharp/RSPEC-2092/

Rule retrieved at	2026-10-18T09:48:34.658Z
Rule security mappings	cwe:311, cwe:315, cwe:614, owaspAsvs-4.0:3.4.1, owaspAsvs-4.0:6.1.1, owaspAsvs-4.0:6.1.2, owaspAsvs-4.0:6.1.3, owaspTop10-2021:a4, owaspTop10-2021:a5, owaspTop10:a3, pciDss-3.2:6.5.10, pciDss-4.0:6.2.4, stig-ASD_V5R3:V-222576

Context still needed

- Whether this snapshot matches the build and deployed system being assessed.
- Relevant trust boundaries, reachable inputs and compensating controls; no runtime proof is included.
- Whether a proposed change preserves intended behavior and passes appropriate tests.

Questions above are review prompts, not claims that a vulnerability was exploited or a fix validated.

ISSUE 7 OF 13

SQL queries should not be dynamically formatted

AaEkwysMn3atgy46CG_S

Legacy severity: MAJOR | Status: OPEN | Issue status: OPEN

Rule ID	csharpsquid:S2077
Type	VULNERABILITY
File/component	mikelopster_sonarqube-training-team-notes:api/Endpoints/Mutations.cs
Reported range	42–42
Created / updated	2026-10-10T07:40:51+0000 / 2026-10-10T07:40:51+0000

What Sonar reported

Use a parameterized query instead of string formatting.

Software-quality impacts: MAINTAINABILITY: LOW; SECURITY: MEDIUM

Source excerpt at the reported location

```
37          {
38              return null;
39          }
40
41          string sql = $"UPDATE {table} SET {string.Join(", ", sets)} WHERE id = @id RETURNING id";
42          var rows = (await conn.QueryAsync<int>(sql, parameters)).ToList();
43          return rows.Count > 0 ? rows[0] : null;
44      }
45
46      public static Dictionary<string, object?> FromJson(Dictionary<string, JsonElement>? body)
47      {
```

Source provenance	SonarCloud api/sources/raw and api/sources/lines, branch=master
Published source file	detailed/sources/api/Endpoints/Mutations.cs
Raw API bytes SHA-256	a578059424d2cd225e589c6333bcbe8aac4430b71135be698256b14a78985800
Published file SHA-256	a578059424d2cd225e589c6333bcbe8aac4430b71135be698256b14a78985800
Hash definition	sha256 of the full UTF-8 response bytes from SonarCloud api/sources/raw, before publication redaction; not a Git commit or deployment identity
Analyzed SCM revision	Unknown / not supplied

Flow locations included in the export

Exported flow 1 · original order

1. mikelopster_sonarqube-training-team-notes:api/Endpoints/Mutations.cs · lines 41–41
   SQL Query is dynamically formatted and assigned to sql.

Rule guidance

Source-linked explanatory summary, not a verified fix for this application.

Why this rule raises the issue

Building SQL by formatting or concatenating values can let data alter query syntax.

Potential risks described by the rule

Untrusted values may change a database operation or expose data; inspection of the surrounding input and authorization checks is still required.

Remediation guidance from the rule

Bind values through the database API parameters and review any dynamic identifiers against a controlled mapping. Verify intended queries and negative cases.

Rule reference: https://rules.sonarsource.com/csharp/RSPEC-2077/

Rule retrieved at	2026-10-18T09:48:35.035Z
Rule security mappings	cwe:89, cwe:943, owaspAsvs-4.0:5.1.3, owaspAsvs-4.0:5.1.4, owaspAsvs-4.0:5.3.4, owaspAsvs-4.0:5.3.5, owaspTop10-2021:a3, owaspTop10:a1, pciDss-3.2:6.5.1, pciDss-4.0:6.2.4

Context still needed

- Whether this snapshot matches the build and deployed system being assessed.
- Relevant trust boundaries, reachable inputs and compensating controls; no runtime proof is included.
- Whether a proposed change preserves intended behavior and passes appropriate tests.

Questions above are review prompts, not claims that a vulnerability was exploited or a fix validated.

ISSUE 8 OF 13

Server-side requests should not be vulnerable to forging attacks

AaEkwyrXn3atgy46CG_H

Legacy severity: MAJOR | Status: OPEN | Issue status: OPEN

Rule ID	roslyn.sonaranalyzer.security.cs:S5144
Type	VULNERABILITY
File/component	mikelopster_sonarqube-training-team-notes:api/Endpoints/PreviewEndpoints.cs
Reported range	33–33
Created / updated	2026-10-10T07:40:51+0000 / 2026-10-10T07:40:51+0000

What Sonar reported

Server-Side Request Forgery via unsanitized user input in PreviewEndpoints.PreviewAsync()

Software-quality impacts: SECURITY: MEDIUM

Source excerpt at the reported location

```
28          if (string.IsNullOrEmpty(url)) return Results.Json(new { error = "url is required" },
    statusCode: 400);
29
30          try
31          {
32              var http = httpFactory.CreateClient("preview");
33              var res = await http.GetAsync(url);
34              string html = await res.Content.ReadAsStringAsync();
35              string? title = TitleTag().Match(html) is { Success: true } m ? m.Groups[1].Value :
    null;
36
37              // Lab 6 (SCA): parse embedded JSON-LD metadata with Newtonsoft.Json (the pinned
38              // vulnerable package). This reaches the deep-recursion parser flagged by the advisory.
```

Source provenance	SonarCloud api/sources/raw and api/sources/lines, branch=master
Published source file	detailed/sources/api/Endpoints/PreviewEndpoints.cs
Raw API bytes SHA-256	8b9fcafaee8dccb8be92c6282c22a8c09925340c9306e653c7ba71680061a746
Published file SHA-256	8b9fcafaee8dccb8be92c6282c22a8c09925340c9306e653c7ba71680061a746
Hash definition	sha256 of the full UTF-8 response bytes from SonarCloud api/sources/raw, before publication redaction; not a Git commit or deployment identity
Analyzed SCM revision	Unknown / not supplied

Flow locations included in the export

Exported flow 1 · original order

1. mikelopster_sonarqube-training-team-notes:api/Endpoints/PreviewEndpoints.cs · lines 33–33
   Sink: this invocation is not safe; a malicious value can be used as argument
2. mikelopster_sonarqube-training-team-notes:api/Endpoints/PreviewEndpoints.cs · lines 27–27
   A malicious value can be assigned to variable ‘url’
3. mikelopster_sonarqube-training-team-notes:api/Endpoints/PreviewEndpoints.cs · lines 27–27
   This invocation can propagate malicious content to its return value
4. mikelopster_sonarqube-training-team-notes:api/Endpoints/PreviewEndpoints.cs · lines 27–27
   This invocation can propagate malicious content to its return value
5. mikelopster_sonarqube-training-team-notes:api/Endpoints/PreviewEndpoints.cs · lines 27–27
   Source: a user can craft an HTTP request with malicious content

Rule guidance

Source-linked explanatory summary, not a verified fix for this application.

Why this rule raises the issue

An attacker-controlled destination can cause a server to make requests on the attacker’s behalf.

Potential risks described by the rule

Depending on reachable services and returned data, SSRF can disclose information or trigger unauthorized actions. Rule context alone does not prove reachability.

Remediation guidance from the rule

Constrain destinations and protocols to the business requirement, validate redirects and resolution, and use network controls. Verify allowed and rejected requests using authorized targets.

Rule reference: https://rules.sonarsource.com/csharp/RSPEC-5144/

Rule retrieved at	2026-10-18T09:48:35.336Z
Rule security mappings	cwe:20, cwe:918, owaspAsvs-4.0:12.6.1, owaspAsvs-4.0:5.1.3, owaspAsvs-4.0:5.1.4, owaspAsvs-4.0:5.2.6, owaspTop10-2021:a10, owaspTop10:a5, pciDss-3.2:6.5.1, pciDss-4.0:6.2.4, stig-ASD_V5R3:V-222609

Context still needed

- Whether this snapshot matches the build and deployed system being assessed.
- Relevant trust boundaries, reachable inputs and compensating controls; no runtime proof is included.
- Whether a proposed change preserves intended behavior and passes appropriate tests.

Questions above are review prompts, not claims that a vulnerability was exploited or a fix validated.

ISSUE 9 OF 13

PostgreSQL database passwords should not be disclosed

AaEkwysdn3atgy46CG_U

Legacy severity: BLOCKER | Status: OPEN | Issue status: OPEN

Rule ID	secrets:S6698
Type	VULNERABILITY
File/component	mikelopster_sonarqube-training-team-notes:api/appsettings.json
Reported range	11–11
Created / updated	2026-10-10T07:40:51+0000 / 2026-10-10T07:40:51+0000

What Sonar reported

Make sure this PostgreSQL password gets changed and removed from the code.

Software-quality impacts: SECURITY: BLOCKER

Source excerpt at the reported location

```
6     }
7   },
8   "AllowedHosts": "*",
9   "_note": "Training app - every secret below is FAKE and exists only for the SonarQube labs.",
10  "ConnectionStrings": {
11    "Default": "postgres://notes:[REDACTED]@db.staging.internal:5432/notes"
12  },
13  "Jwt": {
14    "SigningKey": "[REDACTED]"
15  },
16  "Aws": {
```

Source provenance	SonarCloud api/sources/raw and api/sources/lines, branch=master
Published source file	detailed/sources/api/appsettings.json
Raw API bytes SHA-256	efe85509d9ded8498a8ab8aeb4efe255896d308f858ac3c5be8724042fb013ea
Published file SHA-256	214eb1516627da4b71c1ccd9ce43748668e1273834c78821ff9bbfbe46f713f4
Hash definition	sha256 of the full UTF-8 response bytes from SonarCloud api/sources/raw, before publication redaction; not a Git commit or deployment identity
Analyzed SCM revision	Unknown / not supplied

Credential literals were masked in the published copy at lines 11, 14, 19, 20. The raw-response hash and published-file hash are separate identities. Source structure/line numbers are preserved; a mask is not the original credential.

Flow locations included in the export

No flow locations supplied. This does not prove that data flow is absent.

Rule guidance

Source-linked explanatory summary, not a verified fix for this application.

Why this rule raises the issue

The rule identifies a PostgreSQL password in source.

Potential risks described by the rule

A disclosed database password may permit unauthorized access according to the account permissions and network exposure.

Remediation guidance from the rule

Revoke or change exposed credentials, remove the value from uncontrolled distribution and use a protected secret source. Verify the real affected account and context.

Rule reference: https://rules.sonarsource.com/secrets/RSPEC-6698/

Rule retrieved at	2026-10-18T09:48:33.712Z
Rule security mappings	cwe:259, cwe:798, owaspAsvs-4.0:2.10.4, owaspAsvs-4.0:3.5.2, owaspAsvs-4.0:6.4.1, owaspTop10-2021:a7, owaspTop10:a3, pciDss-3.2:6.5.10, pciDss-4.0:6.2.4, stig-ASD_V5R3:V-222642

Context still needed

- Whether this snapshot matches the build and deployed system being assessed.
- Relevant trust boundaries, reachable inputs and compensating controls; no runtime proof is included.
- Whether a proposed change preserves intended behavior and passes appropriate tests.

Questions above are review prompts, not claims that a vulnerability was exploited or a fix validated.

ISSUE 10 OF 13

Credentials should not be hard-coded

AaEkwysdn3atgy46CG_V

Legacy severity: MAJOR | Status: OPEN | Issue status: OPEN

Rule ID	csharpsquid:S2068
Type	VULNERABILITY
File/component	mikelopster_sonarqube-training-team-notes:api/appsettings.json
Reported range	11–11
Created / updated	2026-10-10T07:40:51+0000 / 2026-10-10T07:40:51+0000

What Sonar reported

Review this hard-coded URI, which may contain a credential.

Software-quality impacts: SECURITY: MEDIUM

Source excerpt at the reported location

```
6       }
7     },
8     "AllowedHosts": "*",
9     "_note": "Training app - every secret below is FAKE and exists only for the SonarQube labs.",
10    "ConnectionStrings": {
11      "Default": "postgres://notes:[REDACTED]@db.staging.internal:5432/notes"
12    },
13    "Jwt": {
14      "SigningKey": "[REDACTED]"
15    },
16    "Aws": {
```

Source provenance	SonarCloud api/sources/raw and api/sources/lines, branch=master
Published source file	detailed/sources/api/appsettings.json
Raw API bytes SHA-256	efe85509d9ded8498a8ab8aeb4efe255896d308f858ac3c5be8724042fb013ea
Published file SHA-256	214eb1516627da4b71c1ccd9ce43748668e1273834c78821ff9bbfbe46f713f4
Hash definition	sha256 of the full UTF-8 response bytes from SonarCloud api/sources/raw, before publication redaction; not a Git commit or deployment identity
Analyzed SCM revision	Unknown / not supplied

Credential literals were masked in the published copy at lines 11, 14, 19, 20. The raw-response hash and published-file hash are separate identities. Source structure/line numbers are preserved; a mask is not the original credential.

Flow locations included in the export

No flow locations supplied. This does not prove that data flow is absent.

Rule guidance

Source-linked explanatory summary, not a verified fix for this application.

Why this rule raises the issue

Credentials embedded in code or connection strings are distributed with the source or application.

Potential risks described by the rule

Readers of a repository, build artifact or backup may obtain access to the associated service.

Remediation guidance from the rule

Move credentials to an appropriate protected configuration or secrets service. Rotate any genuinely exposed credential; moving it alone does not revoke it.

Rule reference: https://rules.sonarsource.com/csharp/RSPEC-2068/

Rule retrieved at	2026-10-18T09:48:33.307Z
Rule security mappings	cwe:259, cwe:798, owaspAsvs-4.0:2.10.4, owaspAsvs-4.0:3.5.2, owaspAsvs-4.0:6.4.1, owaspTop10-2021:a7, owaspTop10:a2, pciDss-3.2:6.5.10, pciDss-4.0:6.2.4

Context still needed

- Whether this snapshot matches the build and deployed system being assessed.
- Relevant trust boundaries, reachable inputs and compensating controls; no runtime proof is included.
- Whether a proposed change preserves intended behavior and passes appropriate tests.

Questions above are review prompts, not claims that a vulnerability was exploited or a fix validated.

ISSUE 11 OF 13

JavaScript package manager scripts should not be executed during installation

AaEkwys4n3atgy46CG_e

Legacy severity: MAJOR | Status: OPEN | Issue status: OPEN

Rule ID	docker:S6505
Type	VULNERABILITY
File/component	mikelopster_sonarqube-training-team-notes:web/Dockerfile
Reported range	7–7
Created / updated	2026-10-10T07:40:51+0000 / 2026-10-10T07:40:51+0000

What Sonar reported

Omitting "--ignore-scripts" allows lifecycle scripts to run during package installation.

Software-quality impacts: SECURITY: MEDIUM

Source excerpt at the reported location

```
2
3  # ---- 1) install dependencies -------------------------------------------------
4  FROM node:24-alpine AS deps
5  WORKDIR /app
6  COPY web/package.json web/package-lock.json ./
7  RUN npm ci
8
9  # ---- 2) build Next.js (standalone output) ------------------------------------
10 FROM node:24-alpine AS build
11 WORKDIR /app
12 ENV NEXT_TELEMETRY_DISABLED=1
```

Source provenance	SonarCloud api/sources/raw and api/sources/lines, branch=master
Published source file	detailed/sources/web/Dockerfile
Raw API bytes SHA-256	8fed2a994af32d83003db28bbb947978f4ba8f9503bd72c8d07fb8e95a5e58f7
Published file SHA-256	8fed2a994af32d83003db28bbb947978f4ba8f9503bd72c8d07fb8e95a5e58f7
Hash definition	sha256 of the full UTF-8 response bytes from SonarCloud api/sources/raw, before publication redaction; not a Git commit or deployment identity
Analyzed SCM revision	Unknown / not supplied

Flow locations included in the export

No flow locations supplied. This does not prove that data flow is absent.

Rule guidance

Source-linked explanatory summary, not a verified fix for this application.

Why this rule raises the issue

Package installation can execute lifecycle scripts supplied by dependencies.

Potential risks described by the rule

A compromised dependency can run code with the build process permissions and expose credentials or alter artifacts.

Remediation guidance from the rule

Review whether installation scripts are needed and use the package manager controls that disable unaudited scripts; test required build functionality afterwards.

Rule reference: https://rules.sonarsource.com/docker/RSPEC-6505/

Rule retrieved at	2026-10-18T09:48:35.644Z
Rule security mappings	cwe:506, cwe:829

Context still needed

- Whether this snapshot matches the build and deployed system being assessed.
- Relevant trust boundaries, reachable inputs and compensating controls; no runtime proof is included.
- Whether a proposed change preserves intended behavior and passes appropriate tests.

Questions above are review prompts, not claims that a vulnerability was exploited or a fix validated.

ISSUE 12 OF 13

Clear-text protocols should not be used

AaEkwytWn3atgy46CG_i

Legacy severity: MINOR | Status: OPEN | Issue status: OPEN

Rule ID	typescript:S5332
Type	VULNERABILITY
File/component	mikelopster_sonarqube-training-team-notes:web/lib/api.ts
Reported range	3–3
Created / updated	2026-10-10T07:40:51+0000 / 2026-10-10T07:40:51+0000

What Sonar reported

Using http protocol is insecure. Use https instead.

Software-quality impacts: SECURITY: LOW

Source excerpt at the reported location

```
1  import { cookies } from 'next/headers';
2
3  export const API_INTERNAL = process.env.API_INTERNAL_URL ?? 'http://api:8080';
4
5  /** Server-side GET to the API, forwarding the caller's session cookie. */
6  export async function apiGet(path: string): Promise<Response> {
7    const cookieHeader = (await cookies()).toString();
8    return fetch(`${API_INTERNAL}${path}`, {
```

Source provenance	SonarCloud api/sources/raw and api/sources/lines, branch=master
Published source file	detailed/sources/web/lib/api.ts
Raw API bytes SHA-256	19ba15dffe337271e9d3a754c3346c0d07f61eafe641ec07a09a61a06e5ac522
Published file SHA-256	19ba15dffe337271e9d3a754c3346c0d07f61eafe641ec07a09a61a06e5ac522
Hash definition	sha256 of the full UTF-8 response bytes from SonarCloud api/sources/raw, before publication redaction; not a Git commit or deployment identity
Analyzed SCM revision	Unknown / not supplied

Flow locations included in the export

No flow locations supplied. This does not prove that data flow is absent.

Rule guidance

Source-linked explanatory summary, not a verified fix for this application.

Why this rule raises the issue

Clear-text protocols do not protect traffic in transit.

Potential risks described by the rule

An observer or active network attacker may read or modify data; the risk depends on the actual network and transported information.

Remediation guidance from the rule

Use an encrypted transport suitable for the service and verify the deployed connection. Internal development HTTP and production exposure must be assessed separately.

Rule reference: https://rules.sonarsource.com/typescript/RSPEC-5332/

Rule retrieved at	2026-10-18T09:48:35.952Z
Rule security mappings	cwe:200, cwe:319, owaspAsvs-4.0:1.9.1, owaspAsvs-4.0:9.1.1, owaspAsvs-4.0:9.2.2, owaspTop10-2021:a2, owaspTop10:a3, pciDss-3.2:4.1, pciDss-3.2:6.5.4, pciDss-4.0:4.2.1, pciDss-4.0:6.2.4, stig-ASD_V5R3:V-222397, stig-ASD_V5R3:V-222534, stig-ASD_V5R3:V-222562, stig-ASD_V5R3:V-222563, stig-ASD_V5R3:V-222577, stig-ASD_V5R3:V-222596, stig-ASD_V5R3:V-222597, stig-ASD_V5R3:V-222598, stig-ASD_V5R3:V-222599

Context still needed

- Whether this snapshot matches the build and deployed system being assessed.
- Relevant trust boundaries, reachable inputs and compensating controls; no runtime proof is included.
- Whether a proposed change preserves intended behavior and passes appropriate tests.

Questions above are review prompts, not claims that a vulnerability was exploited or a fix validated.

ISSUE 13 OF 13

Clear-text protocols should not be used

AaEkwytjn3atgy46CG_k

Legacy severity: MINOR | Status: OPEN | Issue status: OPEN

Rule ID	typescript:S5332
Type	VULNERABILITY
File/component	mikelopster_sonarqube-training-team-notes:web/next.config.ts
Reported range	5–5
Created / updated	2026-10-10T07:40:51+0000 / 2026-10-10T07:40:51+0000

What Sonar reported

Using http protocol is insecure. Use https instead.

Software-quality impacts: SECURITY: LOW

Source excerpt at the reported location

```
1  import type { NextConfig } from 'next';
2
3  // Calls to /api/* in the browser are proxied to the ASP.NET Core API (server-to-server),
4  // so the browser stays same-origin with the web app and cookies just work.
5  const API_INTERNAL = process.env.API_INTERNAL_URL ?? 'http://api:8080';
6
7  const nextConfig: NextConfig = {
8    output: 'standalone',
9    async rewrites() {
10     return [{ source: '/api/:path*', destination: `${API_INTERNAL}/api/:path*` }];
```

Source provenance	SonarCloud api/sources/raw and api/sources/lines, branch=master
Published source file	detailed/sources/web/next.config.ts
Raw API bytes SHA-256	67d3a149ab53857474a4b2c0ccac45614f61bd9efd9bc3bc83b2deaeeafb21a5
Published file SHA-256	67d3a149ab53857474a4b2c0ccac45614f61bd9efd9bc3bc83b2deaeeafb21a5
Hash definition	sha256 of the full UTF-8 response bytes from SonarCloud api/sources/raw, before publication redaction; not a Git commit or deployment identity
Analyzed SCM revision	Unknown / not supplied

Flow locations included in the export

No flow locations supplied. This does not prove that data flow is absent.

Rule guidance

Source-linked explanatory summary, not a verified fix for this application.

Why this rule raises the issue

Clear-text protocols do not protect traffic in transit.

Potential risks described by the rule

An observer or active network attacker may read or modify data; the risk depends on the actual network and transported information.

Remediation guidance from the rule

Use an encrypted transport suitable for the service and verify the deployed connection. Internal development HTTP and production exposure must be assessed separately.

Rule reference: https://rules.sonarsource.com/typescript/RSPEC-5332/

Rule retrieved at	2026-10-18T09:48:35.952Z
Rule security mappings	cwe:200, cwe:319, owaspAsvs-4.0:1.9.1, owaspAsvs-4.0:9.1.1, owaspAsvs-4.0:9.2.2, owaspTop10-2021:a2, owaspTop10:a3, pciDss-3.2:4.1, pciDss-3.2:6.5.4, pciDss-4.0:4.2.1, pciDss-4.0:6.2.4, stig-ASD_V5R3:V-222397, stig-ASD_V5R3:V-222534, stig-ASD_V5R3:V-222562, stig-ASD_V5R3:V-222563, stig-ASD_V5R3:V-222577, stig-ASD_V5R3:V-222596, stig-ASD_V5R3:V-222597, stig-ASD_V5R3:V-222598, stig-ASD_V5R3:V-222599

Context still needed

- Whether this snapshot matches the build and deployed system being assessed.
- Relevant trust boundaries, reachable inputs and compensating controls; no runtime proof is included.
- Whether a proposed change preserves intended behavior and passes appropriate tests.

Questions above are review prompts, not claims that a vulnerability was exploited or a fix validated.

Dependency risk evidence · SCA

One OPEN HIGH dependency vulnerability recorded for Newtonsoft.Json12.0.3; API provides CVE/GHSA, version options and reachable source locations.

SCA status updated at	2026-10-16T18:39:20.125Z
Timestamp meaning	SCA analyses API updatedAt, not a Git commit or the core code analysis timestamp
Collection captured at	2026-10-18T09:52:41.122Z
SCA status	COMPLETED
Risk records returned	1

> This SCA timestamp is separate from the 10 October core code analysis. These records do not establish a matching Git commit or deployed dependency version.

CVE-2024-21907 · Newtonsoft.Json 12.0.3

Risk ID	0ef118b9-0da3-4085-a4c6-e69dc0a1ea27
Package URL	pkg:nuget/Newtonsoft.Json@12.0.3
Package manager	NUGET
Reported status	OPEN
Severity / CVSS	HIGH / 7.5
Affected paths reported	api/Api.csproj, api/project.assets.json
hasReachableLocations	True

Advisory description

The exported advisory links Newtonsoft.Json versions before 13.0.1 with a possible denial of service when crafted data reaches JsonConvert.DeserializeObject. It describes StackOverflowException as the failure mode; exposure depends on the application.

Reachability reported by the analyzer

Call signature	Newtonsoft.Json.JsonConvert.DeserializeObject(string)
Signature type	PUBLIC_CALLER
Location	api/Endpoints/PreviewEndpoints.cs:43–43

> The API flag and call location are analyzer evidence. They are not an observed exploit, unauthenticated endpoint proof, or proof that this package is deployed.

Remediation metadata returned by the API

Recommendation	upgrade
Unaffected version range	>= 13.0.1

Version option	API description	Fix level	Prerelease
12.0.3	VERSION_IN_USE	NONE	False
13.0.1	NEAREST_COMPLETE	COMPLETE	False
13.0.4	LATEST_STABLE	COMPLETE	False
14.0.1-beta2	LATEST_PRERELEASE	COMPLETE	True

These are captured API options, not completed upgrades or verified compatibility. A prerelease option is not automatically the appropriate choice.

References

- CVE-2024-21907
- GHSA-5crp-9r3c-p9vr

Limits of this record

- Reachability locations are analyzer evidence, not a runtime exploit or proof of deployed package identity.
- Version recommendations/EPSS are captured API metadata and not a completed upgrade, compatibility test or current live recommendation.
- SCA status updatedAt differs from the core code-analysis date; no analyzed SCM commit was supplied.

Coverage gaps and source availability

Reported analysis error	MISSING_LOCKFILE
Path	api.Tests/Api.Tests.csproj
Message	No lockfile was found for 'api.Tests/Api.Tests.csproj' (nuget).
Requested source path	api/Api.csproj
Source API HTTP status	404
Requested source path	api/project.assets.json
Source API HTTP status	404

Listed artifact paths are SCA metadata. A source API 404 means the file content was unavailable from that request; it is not evidence that the file is absent from every build or deployment.

Package inventory total reported	221
Complete inventory exported	False
Sample package rows supplied	1
Full listing HTTP status	403
Full listing result	API returned403 to direct browser-session fetch; no missing package rows inferred.

A count or a sample is not a full SBOM. Do not fill missing package rows from assumptions.

Hotspots, gate and metric evidence

Security Hotspots

Captured at	2026-10-18T09:48:35.952Z
Returned hotspots	0
Query	Recorded branch master; paging preserved in detailed/hotspots.json

No hotspot records were returned for this exported query.

Quality gate API response

Status	NONE
Conditions returned	0

API returned NONE with no conditions; this is not a PASS assertion.

Separate branch-list metadata

Branch label	Analysis date	Branch-list qualityGateStatus
solution	2026-10-10T07:43:31+0000	ERROR
master	2026-10-10T07:40:51+0000	OK

Branch-list status and the quality-gate endpoint are separate API fields. Preserve their returned values; do not substitute a branch-list OK for a verified current gate pass.

Exported metrics · raw keys and values

Captured at	2026-10-18T09:52:41.122Z
Scope	branch master; Overall and New Code metric keys remain distinct

Overall values and new-code period values are separate. Numeric rating/severity encodings are not issue counts; missing values remain unavailable. The complete definitions are in detailed/security-metrics.json.

Metric key	Overall/raw value	New-code periods (index: value)
new_sca_count_any_issue	Unknown / not supplied	1: 0
new_sca_count_any_security	Unknown / not supplied	1: 0
new_sca_count_licensing	Unknown / not supplied	1: 0
new_sca_count_malware	Unknown / not supplied	1: 0

Metric key	Overall/raw value	New-code periods (index: value)
new_sca_count_vulnerability	Unknown / not supplied	1: 0
new_sca_rating_any_issue	Unknown / not supplied	1: 1.0
new_sca_rating_any_security	Unknown / not supplied	1: 1.0
new_sca_rating_licensing	Unknown / not supplied	1: 1.0
new_sca_rating_malware	Unknown / not supplied	1: 1.0
new_sca_rating_vulnerability	Unknown / not supplied	1: 1.0
new_sca_severity_any_issue	Unknown / not supplied	1: 0
new_sca_severity_any_security	Unknown / not supplied	1: 0
new_sca_severity_licensing	Unknown / not supplied	1: 0
new_sca_severity_malware	Unknown / not supplied	1: 0
new_sca_severity_vulnerability	Unknown / not supplied	1: 0
sca_count_any_issue	1	Unknown / not supplied
sca_count_any_security	1	Unknown / not supplied
sca_count_licensing	0	Unknown / not supplied
sca_count_malware	0	Unknown / not supplied
sca_count_vulnerability	1	Unknown / not supplied
sca_rating_any_issue	4.0	Unknown / not supplied
sca_rating_any_security	4.0	Unknown / not supplied
sca_rating_licensing	1.0	Unknown / not supplied
sca_rating_malware	1.0	Unknown / not supplied
sca_rating_vulnerability	4.0	Unknown / not supplied
sca_severity_any_issue	20	Unknown / not supplied
sca_severity_any_security	20	Unknown / not supplied

Metric key	Overall/raw value	New-code periods (index: value)
sca_severity_licensing	0	Unknown / not supplied
sca_severity_malware	0	Unknown / not supplied
sca_severity_vulnerability	20	Unknown / not supplied
security_hotspots	0	Unknown / not supplied
security_hotspots_reviewed	100.0	Unknown / not supplied
security_hotspots_reviewed_status	0	Unknown / not supplied
security_hotspots_to_review_status	0	Unknown / not supplied
security_issue_severity	25	Unknown / not supplied
security_issues	{"total":13,"HIGH":1,"MEDIUM":6,"LOW":4,"INFO":0,"BLOCKER":2}	Unknown / not supplied
security_rating	5.0	Unknown / not supplied
security_remediation_effort	335	Unknown / not supplied
security_review_rating	1.0	Unknown / not supplied
software_quality_security_issues	13	Unknown / not supplied
vulnerabilities	13	Unknown / not supplied

Requested metric keys not returned

- new_security_hotspots
- new_security_hotspots_reviewed
- new_security_hotspots_reviewed_status
- new_security_hotspots_to_review_status
- new_security_issue_severity
- new_security_issues
- new_security_rating
- new_security_remediation_effort
- new_security_review_rating
- new_software_quality_security_issues
- new_vulnerabilities
- new_vulnerabilities_severity

Missing metric keys are unavailable, not zero; encoded JSON metric values are preserved as returned.

Source inventory and limitations

File	detailed/bundle.json
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	1a4fa5fd3e02e481e6f1913877de4f2e6d6dd40c8f26e3a19dd1ce8385c6457e
Captured at	Mixed capture set; see core and supplemental timestamps above
File	detailed/collection.json
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	279dece19fa7475855d7a2236b26a8dea1c7405a2954b1e57d5808a4accda9cc
Captured at	2026-10-18T09:48:35.952Z
File	detailed/dependency-risks.json
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	1a963235d2d9e960038375c9e6650bcb3b5c505e0e98ced3c49f7a996eb5b676
Captured at	2026-10-18T09:52:41.122Z
File	detailed/hotspots.json
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	a8bc8ca42c6c8b09e21b7641f5d2eeb5f652c422b68af1d98e998047b1671631
Captured at	2026-10-18T09:48:35.952Z
File	detailed/issues.json
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	604b338b3a3e38df50be2dfd03a57a1eba15dee912e7de5f5ad48fc1db6f021a
Captured at	2026-10-18T09:48:35.952Z
File	detailed/omitted-fields.json
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	ee9fe414c0c4db27d7295894ea0892ea52ab30774f4b33ce499d63ec68a7f7af
Captured at	2026-10-18T09:48:35.952Z

File	detailed/project-metadata.json
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	166af51b504ca932d0c387c8f2a98805a53d1ee943f8766b17ea67b45c9aea3b
Captured at	Mixed capture set; see core and supplemental timestamps above

File	detailed/rules.json
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	a2f1162720b5d62ea146e2e0651ae20c1fe10130ac9c444636f6be4574ae66f1
Captured at	2026-10-18T09:48:35.952Z

File	detailed/scope.json
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	74a97b5a8d34568a22d55286865e20132e338a58216ae4f3eae59f1ac2c124b5
Captured at	2026-10-18T03:44:34.355Z

File	detailed/security-groupings.json
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	86024164a4ce062b65461d1bb58a9ef927233af219e23ac7b1c7b2c2e47806bb
Captured at	2026-10-18T09:48:35.952Z

File	detailed/security-metrics.json
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	9a9d9b0018922852307380231 1a4a906622cdd224f8236d6d48ac7fb564cc50c
Captured at	2026-10-18T09:52:41.122Z

File	detailed/source-manifest.json
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	ce585240471bc59138154fe3c063805e52549145ce857aaeaac6b7491a053ff9
Captured at	2026-10-18T09:48:35.952Z

File	detailed/sources/.github/workflows/sonarqube.yml
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	872c78f32207267b52730cebd921972def6c51aabda5a1b493a041a61afc40ef
Captured at	2026-10-18T09:48:35.952Z

File	detailed/sources/api/AppConfig.cs
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	a1ce736977d9268d91d200153af48ed30330fb7841b2f89f744aa6a6f73ef04c
Captured at	2026-10-18T09:48:35.952Z

File	detailed/sources/api/Auth.cs
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	613c2eb914ba9ad92d82d215c9ea5e20cc9ac4ff8de42afeac42f19d8faff948
Captured at	2026-10-18T09:48:35.952Z

File	detailed/sources/api/Endpoints/AuthEndpoints.cs
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	18310475693c4cb410773fc048320bc0793ad060aa8b8ff74d0c269b00479a5e
Captured at	2026-10-18T09:48:35.952Z

File	detailed/sources/api/Endpoints/Mutations.cs
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	a578059424d2cd225e589c6333bcbe8aac4430b71135be698256b14a78985800
Captured at	2026-10-18T09:48:35.952Z

File	detailed/sources/api/Endpoints/PreviewEndpoints.cs
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	8b9fcafaee8dccb8be92c6282c22a8c09925340c9306e653c7ba71680061a746
Captured at	2026-10-18T09:48:35.952Z

File	detailed/sources/api/appsettings.json
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	214eb1516627da4b71c1ccd9ce43748668e1273834c78821ff9bbfbe46f713f4
Captured at	2026-10-18T09:48:35.952Z

File	detailed/sources/web/Dockerfile
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	8fed2a994af32d83003db28bbb947978f4ba8f9503bd72c8d07fb8e95a5e58f7
Captured at	2026-10-18T09:48:35.952Z

File	detailed/sources/web/lib/api.ts
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	19ba15dffe337271e9d3a754c3346c0d07f61eafe641ec07a09a61a06e5ac522
Captured at	2026-10-18T09:48:35.952Z

File	detailed/sources/web/next.config.ts
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	67d3a149ab53857474a4b2c0ccac45614f61bd9efd9bc3bc83b2deaeeafb21a5
Captured at	2026-10-18T09:48:35.952Z

File	detailed/supplemental.json
Origin	Sanitized normalized export; original raw API responses retained privately
SHA-256	a57a3b24c2b410ee0fff02d6743982f68bb2ed652d080d7c40f8bab7f424e6a5
Captured at	Mixed capture set; see core and supplemental timestamps above

- Initial rules/show requests returned400 because organization was required; each was retried successfully with the project organization.
- Issue status and rule metadata are current API state for the recorded analysis source, not newly executed scans.
- No runtime test, exploit, setting change or rescan performed.

Compiled teaching companion. Original exports and the native PDF remain the authoritative source records. Analysis, export, and document-generation times are distinct.